



Government
Digital Service



Department for
Science, Innovation
& Technology

Aligning data loss prevention (DLP) strategies with Secure by Design

September 2025

Contents

Background	3
Purpose	3
Secure by Design on the UK Government Security website	3
1. Components of DLP strategies and how they align with Secure By Design	4
1.1 Data classification and labelling	4
1.2 Policy and governance	5
1.3 Technical controls	6
1.4 Training and awareness	7
1.5 Incident response	7
1.6 Monitoring and continuous improvement	8
1.7 Legal, regulatory and compliance alignment	9
1.8 Implementation roadmap	10
2. Best practices	12
2.1 Adopt Zero Trust	12
2.2 Embed DLP into cloud-first strategy	12
2.3 Regular risk assessments using the Cyber Assessment Framework (CAF)	12
2.4 Cross-department collaboration	13
3. Challenges in government DLP	14
3.1 Balancing security against productivity	14
3.2 Older systems that do not support modern DLP tools	14
3.3 Managing third-party contractors and suppliers in complex supply chains	14
3.4 Cultural resistance	14
4. More information	16

Background

Data is one of the most valuable assets for government organisations. Protecting sensitive, personal and classified information is not only about regulatory compliance but also national security and public trust. Data loss prevention (DLP) provides the tools and policies that can prevent accidental or malicious data breaches.

The government's Secure by Design approach mainly concentrates on cyber resilience across digital services. Integrating Secure by Design principles into a DLP strategy helps significantly improve how organisations approach data security.

Instead of implementing DLP as an isolated, reactive solution after systems are deployed, aligning it with Secure by Design makes sure that data protection is intentionally embedded into the system architecture, development processes and operational workflows from the very beginning.

This proactive approach minimises security gaps and reduces the reliance on unplanned or bolt-on solutions that are often difficult to manage and scale.

Purpose

The purpose of this document is to align DLP strategies with the government's [Secure by Design principles](#) and [activities](#). By integrating the Secure by Design approach into DLP strategies, government organisations can make sure data protection is embedded into systems, services and processes from the start.

Secure by Design on the UK Government Security website

- [Secure by Design policy](#)
- [Implementing Secure by Design](#)
- [Guide to adopting Secure by Design](#)

1. Components of DLP strategies and how they align with Secure By Design

Using the Secure by Design framework to shape DLP strategies makes sure that the protection of sensitive data is not reactive but systematic, deliberate and resilient. When government organisations align classification, governance, technical enforcement, training, incident response and monitoring with the Secure by Design principles and activities, they establish a foundation for secure and trusted service delivery.

There are many benefits to this alignment. It:

- reduces the likelihood of data loss incidents
- enhances organisational resilience
- strengthens compliance
- builds public trust

It also allows organisations to quickly respond to new challenges, such as emerging threats, evolving technology and changes in legislation.

1.1 Data classification and labelling

Principles supported:

- 1. Create responsibility for cyber security risk
- 3. Adopt a risk-driven approach
- 4. Design usable security controls
- 5. Build in detect and respond security
- 6. Design flexible architectures

Classification and labelling are a key part of a DLP framework. By classifying data using categories such as OFFICIAL, SECRET and TOP SECRET under the [Government Security Classifications Policy \(GSCP\)](#), organisations establish a baseline for protective measures. By requiring data ownership and accountability to be clearly defined, this process supports principle 1 (Create responsibility for cyber security risk).

Classification is dependent on how much impact data loss or disclosure might have. This approach supports principle 3 (Adopt a risk-driven approach). Activities like [Documenting service assets](#) and [Performing threat modelling](#) make sure that data receives the level of protection appropriate to its sensitivity.

When classification labels are straightforward and consistently applied, users are more likely to adopt the labelling system and the organisation meets principle 4 (Design usable security controls).

Government organisations can operationalise this by using automated tools that identify sensitive data across structured and unstructured repositories. Operationalisation helps makes DLP:

- sustainable
- enforceable
- scalable

Advanced discovery tools can scan file shares, cloud storage and email archives to highlight where sensitive data resides and apply labels consistently. Having automated enforcement in place means human errors are addressed, aligning with principle 5 (Build in detect and respond security).

Classification should also evolve over time. Data sensitivity may change due to:

- updates to legislation
- shifting public expectations
- new threat scenarios

Integrating periodic reviews of systems into governance processes helps keep classification accurate. This makes sure organisations are adaptable to emerging needs, supporting principle 6 (Design flexible architectures).

Effective labelling requires strong technical underpinnings. Systems must reliably enforce the use of labels and prevent leakage when data is transferred, copied or exported. It's critical to integrate labelling into productivity tools, collaboration platforms and cloud services so that they're adopted by employees. By embedding classification and labelling into daily workflows, organisations strengthen resilience without making things harder for their staff.

Related guidance

- [Secure by Design Principles \(Government Security\)](#)
- [Government Security Classifications Policy \(GOV.UK\)](#)

1.2 Policy and governance

Principles supported:

- 1. Create responsibility for cyber security risk
- 2. Source secure technology products
- 3. Adopt a risk-driven approach

Effective policies and governance frameworks provide the foundation for technical and procedural DLP measures. Organisations can embed responsibility and accountability by creating:

- classification schemes
- acceptable use rules
- breach escalation processes

This directly supports principle 1 (Create responsibility for cyber security risk).

Policies should also extend to suppliers so that vendors comply with labelling and handling rules. This aligns with principle 2 (Source secure technology products).

Governance measures should be informed by structured risk assessment activities, as outlined in principle 3 (Adopt a risk-driven approach). For example, activities like [Assessing the importance of service assets](#) provide evidence for determining which policies apply to different types of data. Policy reviews and governance boards provide accountability and embed cyber resilience into wider organisational planning.

Governance must also be adaptive. Organisations should review DLP policies periodically to reflect new risks, evolving technologies and legislative changes. Integrating DLP policy reviews into annual planning cycles keeps them relevant.

Strong governance means that protective measures are:

- documented
- enforced
- supported by senior leadership

1.3 Technical controls

Principles supported:

- 4. Design usable security controls
- 5. Build in detect and respond security
- 6. Design flexible architectures
- 7. Minimise the attack surface
- 8. Defend in depth

Technical controls bring DLP strategies to life, turning policy into enforceable safeguards. These include:

- endpoint controls that prevent copying data to unauthorised devices
- email filters that block sensitive content from leaving the organisation
- encryption technologies that secure data both at rest and in transit

These measures align with principle 8 (Defend in depth) by adding layers of protection.

Minimising exposure, as detailed in principle 7 (Minimise the attack surface), involves restricting unnecessary data retention and applying least-privilege access. Activities such as [Retiring service components securely](#) reinforce this.

Integrating classification tools with collaboration platforms like Microsoft Teams or Slack supports principle 4 (Design usable security controls). This can increase compliance from employees without having too much impact on their productivity.

Advanced monitoring tools can also detect unusual behaviour, for example, unexpected data transfers. Integration with Security Information and Event Management (SIEM) or security operations centre (SOC) capabilities allows organisations to correlate DLP alerts with threats. This supports principle 5 (Build in detect and respond security).

Technical controls should be adaptable. As organisations adopt cloud, hybrid and mobile technologies, controls must extend seamlessly across environments. This ensures

resilience in evolving technological landscapes and aligns with principle 6 (Design flexible architectures).

1.4 Training and awareness

Principles supported:

- 1. Create responsibility for cyber security risk
- 9. Embed continuous assurance

A strong DLP strategy requires a culture of awareness across all levels of the organisation. Training programmes make sure staff:

- recognise the importance of classification
- understand policies
- know how to handle sensitive information responsibly

This directly supports principle 1 (Create responsibility for cyber security risk) by making individual and collective duties clear.

Some training needs, for example, a requirement to classify and protect data, are probably the same across your whole organisation. But some training can be risk-based and role-specific: business users may need scenario-driven exercises, while IT and security staff may require deeper technical training.

The activity [Understanding business objectives and user needs](#) can help make sure training is relevant. Exercises and simulations support principle 9 (Embed continuous assurance) by validating whether controls are effective in practice.

Organisations should also carry out regular awareness campaigns. When DLP-related training is embedded into onboarding processes and annual learning requirements, awareness becomes something that's continuously reinforced, rather than simply a one-off activity. Organisations can follow this up by making improvements to DLP strategies based on feedback from training.

1.5 Incident response

Principles supported:

- 5. Build in detect and respond security
- 10. Make changes securely

Being prepared to respond to data loss incidents is critical. DLP tools generate alerts when sensitive data is mishandled, which helps with detection. This supports principle 5 (Build in detect and respond security). Carrying out the activities [Managing observability](#) and [Responding to and mitigating security risks](#) makes sure that organisations follow detection with swift, coordinated action.

Organisations should include classification-specific playbooks in incident response plans to guide staff on escalation and remediation. It's important to regularly test these plans through simulations and exercises. This supports principle 10 (Make changes securely).

Follow this up by incorporating lessons learned into updated procedures. Every incident should ultimately strengthen the resilience of the organisation.

1.6 Monitoring and continuous improvement

Principles supported:

- 6. Design flexible architectures
- 9. Embed continuous assurance

Monitoring provides the essential feedback loop that enables organisations to understand whether DLP measures are working as intended.

Effective monitoring goes beyond dashboards and log analysis; it requires a structured process of continuous review, validation and adaptation. This is particularly important in environments where threats evolve rapidly, quickly making static controls outdated. By investing in advanced monitoring tools like SIEM systems and behavioural analytics, organisations can proactively identify anomalies that may signal data leakage.

Aligning with principle 9 (Embed continuous assurance), monitoring should not only focus on the technical layer but also include policy compliance, user behaviour and third-party interactions. Organisations can make sure monitoring is a holistic process with activities such as:

- [Tracking Secure by Design progress](#)
- [Assessing the effectiveness of security controls](#)
- [Evaluating the security impact of changes](#)

Independent audits and external reviews can provide additional assurance, giving leadership confidence that the organisation's data protection strategy is both comprehensive and effective.

Continuous improvement makes sure that insights from monitoring are used to refine security practices. Use lessons learned from incidents, audit findings and user feedback to:

- enhance classification schemes
- update training
- improve incident response protocols

This approach strengthens resilience and helps organisations comply with changing regulatory and legislative frameworks. It also supports principle 6 (Design flexible architectures) by making sure that DLP measures can adapt to technological change, such as migration to cloud platforms or the adoption of new collaboration tools.

To operationalise continuous improvement, organisations should:

- establish regular governance meetings to review monitoring reports
- track key performance indicators (KPIs), such as policy violation rates or incident resolution times
- define remedial actions

By embedding monitoring into the culture, organisations can make sure DLP strategies evolve alongside both operational needs and threat landscapes.

1.7 Legal, regulatory and compliance alignment

Principles supported:

- 2. Source secure technology products
- 3. Adopt a risk-driven approach

DLP strategies are effective not only when they prevent breaches, but also when they're aligned with legal and regulatory obligations.

UK government organisations operate under a range of legislative frameworks, including the [Data Protection Act 2018](#), [UK GDPR](#), the [Official Secrets Act 1989](#) and sector-specific regulations. DLP strategies must make sure that classification, labelling and handling practices meet statutory obligations. This directly supports principle 3 (Adopt a risk-driven approach), since compliance obligations help prioritise which protective measures to take.

The following activities help ensure legal requirements are continuously reviewed as new guidance and legislation emerges:

- [Responding to and mitigating security risks](#)
- [Evaluating the security impact of changes](#)
- [Retiring service components securely](#)

For example, organisations should update DLP policies and controls promptly when there are changes in guidance from the Information Commissioner's Office (ICO).

Compliance also extends to third parties and suppliers, which aligns with principle 2 (Source secure technology products). Contracts and service agreements should require compliance with UK Government Security Classifications and DLP requirements. This makes sure that sensitive data remains protected even when it is shared outside departments. Supplier audits and assurance assessments can help verify compliance and identify areas for improvement.

Beyond regulatory requirements, embedding compliance into monitoring and reporting processes increases organisations' accountability. This helps organisations show auditors and the public that they've carried out due diligence.

Related guidance

- [UK GDPR guidance and resources \(ICO\)](#)
- [Official Secrets Act 1989 \(Legislation.gov.uk\)](#)
- [The UK's data protection legislation \(GOV.UK\)](#)

- [Contracting securely \(UK Government Security\)](#)

1.8 Implementation roadmap

Implementing a DLP strategy that's fully aligned with Secure by Design requires a structured approach. Each stage should be:

- underpinned by Secure by Design principles
- mapped to measurable outcomes
- reinforced with leadership commitment

So that leadership can track progress and hold teams accountable, each stage should include defined milestones, such as:

- the percentage of classified data under protection
- the average time it takes to detect and respond to incidents
- supplier compliance scores

An implementation roadmap might be made up of the following stages.

Assessment and planning

Organisations should:

- conduct a thorough audit of data assets, data flows and existing security controls
- use risk assessments to prioritise high-value and high-risk information
- define classification schemes and establish governance boards

Policy and quick wins

Organisations should:

- roll out classification policies and assign clear responsibilities
- deploy simple labelling tools in email and file systems to build early momentum
- communicate quick wins to stakeholders to maintain buy-in

Technical controls deployment

Organisations should:

- implement advanced DLP solutions across endpoints, cloud platforms and email systems
- enforce encryption and apply strict access control policies
- make technical solutions a seamless part of user workflows

Incident response integration

Organisations should:

- develop classification-specific playbooks, conduct tabletop exercises and establish escalation processes

- test detection and response capabilities to ensure rapid remediation of incidents

Monitoring and improvement

Organisations should:

- introduce SIEM integrations, reporting dashboards and KPI tracking
- regularly review effectiveness and feed insights into updated policies and training
- benchmark performance against peer organisations and standards

Supplier and third-party management

Organisations should

- extend classification and DLP requirements to third-party vendors
- establish contractual obligations and conduct compliance audits
- make sure suppliers participate in joint incident response exercises

2. Best practices

2.1 Adopt Zero Trust

Adopting a Zero Trust approach means moving away from the traditional idea that everything inside a network perimeter is inherently safe. Instead, Zero Trust operates with the mindset of ‘never trust, always verify’.

This model treats every user, device and application as a potential risk until they are fully authenticated and authorised, and are being monitored. This includes potential risks both inside and outside an organisation’s environment.

By assuming that breaches can occur at any time, organisations create a security posture that is more adaptive and resilient, and capable of minimising damage when attacks happen.

2.2 Embed DLP into cloud-first strategy

For organisations implementing a cloud-first strategy, embedding DLP is vital to protect sensitive, classified and citizen-related data. As departments move critical workloads and services to different cloud platforms, the risk of data exposure, accidental leaks and insider threats increases.

By integrating DLP, departments can consistently monitor, classify and secure data while complying with strict regulatory and security requirements. This strengthens public trust, supports mission readiness and allows organisations to leverage the scalability and efficiency of cloud technologies without compromising data integrity or confidentiality.

2.3 Regular risk assessments using the Cyber Assessment Framework (CAF)

Regular risk assessment using the [Cyber Assessment Framework \(CAF\)](#), which was developed by the National Cyber Security Centre (NCSC), is vital for strengthening an organisation’s resilience to evolving threats.

By systematically evaluating systems, processes and controls against the CAF’s principles, organisations can:

- identify vulnerabilities
- measure maturity levels
- prioritise improvements

This proactive approach:

- makes sure organisations are compliant with recognised standards
- reduces the likelihood of cyber incidents
- enhances stakeholder confidence

In addition, routine assessments enable continuous improvement, aligning cyber risk management with changing technologies, regulatory requirements and threat landscapes.

2.4 Cross-department collaboration

Cross-government collaboration to enhance DLP practices strengthens information security across the public sector. By sharing insights, best practices and threat intelligence, government departments can develop more robust DLP strategies that address common vulnerabilities and emerging risks.

Working together also helps standardise policies, tools and response protocols. This makes sure sensitive data is consistently protected while supporting secure information sharing. This unified approach not only reduces the likelihood of data breaches but also promotes a culture of collective responsibility, improving overall cyber resilience across government.

3. Challenges in government DLP

3.1 Balancing security against productivity

Overly strict DLP policies can create a tension between security and productivity. While strict controls are essential to protect sensitive data and prevent breaches, overly restrictive measures can make it harder for employees to perform their tasks efficiently.

For example, frequent alerts, blocked file transfers or limited access to cloud tools may impact business outcomes if frustrated employees are forced to create workarounds or complete work more slowly. The challenge lies in finding a balance. A nuanced approach should combine risk-based policies, user education and adaptive monitoring.

3.2 Older systems that do not support modern DLP tools

Older systems may not support modern DLP tools. This poses significant challenges for organisations aiming to safeguard sensitive information.

Such legacy technology often lacks the APIs, integration capabilities or security frameworks required by modern DLP solutions. This makes it difficult to monitor, control or prevent the unauthorised transfer of data.

As a result, sensitive files may remain exposed to internal and external threats, creating compliance risks and potential financial or reputational damage. Additionally, retrofitting these systems with modern security controls can be complex, costly and prone to operational disruption. This leaves organisations which are reliant on older systems in a difficult position.

3.3 Managing third-party contractors and suppliers in complex supply chains

A major challenge in government DLP initiatives is managing third-party suppliers who handle sensitive data. These external partners often operate outside the direct control of government security policies, making it difficult to enforce consistent DLP practices.

Differences in technical capabilities, security standards and compliance awareness can create vulnerabilities where sensitive information may be exposed or mishandled. Making sure that suppliers follow strict data protection requirements requires robust contracts, ongoing monitoring and close collaboration.

3.4 Cultural resistance

Cultural resistance is another significant challenge in implementing DLP effectively. Staff may perceive it as a restrictive or punitive measure rather than a security enabler. Overcoming this mindset requires clear communication that positions DLP as a tool that

protects both the organisation and employees from data breaches, compliance risks and reputational damage.

Organisations can help staff understand the benefits of DLP by:

- organising training
- carrying out awareness campaigns
- embedding DLP into everyday workflows

This helps make security a shared responsibility rather than an obstacle.

By fostering a culture where DLP is seen as a strategy that enables safe, efficient work rather than a barrier, organisations can achieve higher adoption, stronger compliance and more effective data protection.

4. More information

- [Secure by Design Principles \(UK Government Security\)](#)
- [Secure by Design Activities \(UK Government Security\)](#)
- [Government Security Classifications Policy \(GOV.UK\)](#)
- [Cyber Assessment Framework \(NCSC.GOV.UK\)](#)
- [Data protection by design and default \(ICO\)](#)
- [National Data Strategy \(GOV.UK\)](#)
- [Data Protection Act 2018 \(ICO\)](#)